

SUPPORT ÉTUDIANT

Paiements Digitaux et Wallets numériques

Jour 3 : Tokenisation



Chrisvene MPANDZOU
chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Définition

DÉFINITION MONÉTIQUE

Qu'est-ce que la tokenisation ?

Substitution du **PAN** par un **token** utilisable dans un **domaine d'usage** (périmètre autorisé : canal, device, parfois marchand), gouverné par une infrastructure dédiée (vault / TSP), afin de **réduire l'exposition** des données carte sans changer la logique monétique **Auth** → **Clearing** → **Settlement**.

On sécurise l'identifiant présenté — pas le rail de paiement.

VOCABULAIRE

Deux identifiants

Deux numéros qui se ressemblent souvent à l'œil — ce n'est pas la même chose.

CARTE PLASTIQUE PAN  PAN — <i>Primary Account Number</i> : numéro de compte carte (souvent 16 chiffres), imprimé ou embossé. Identifiant d'origine, sensible. 4532 1488 0342 7764	WALLET / DEVICE Token  Token : substitut du PAN, émis pour un domaine (device, canal, marchand). Souvent même format — ce n'est <i>pas</i> le numéro de la carte. 4895 3702 1148 0091
---	---

Exemples pédagogiques uniquement. Le PAN reste la racine chez l'émetteur / le vault ; le canal (POS, app) voit le token.

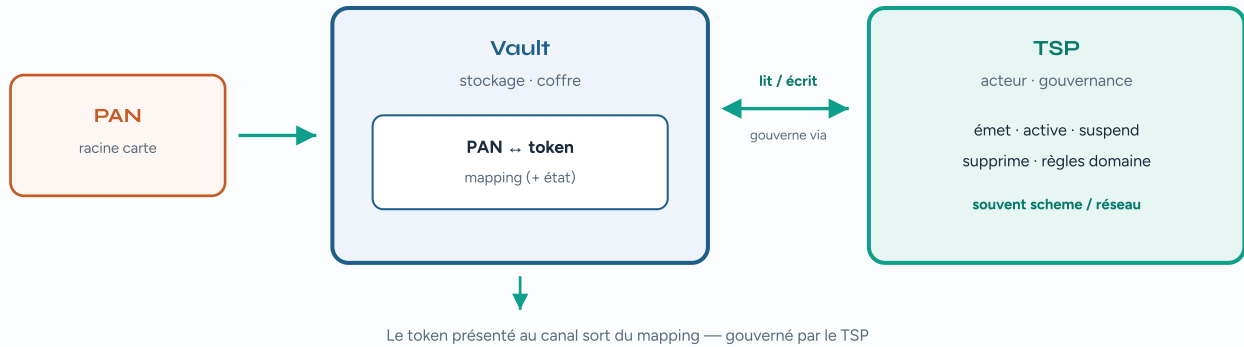
Substitution illustrée



Vault & TSP

Deux briques à ne pas confondre : le **vault** stocke le lien ; le **TSP** gouverne le cycle de vie.

Vault ↔ TSP



Token vault

- Référentiel sécurisé PAN ↔ token
- Où vit la correspondance (pas le canal)
- « Coffre » du mapping — pas l'acteur métier

TSP

- Token Service Provider
- Émet, active, suspend, supprime
- Applique règles de domaine / device
- Souvent scheme, parfois issuer ou acteur dédié

Où dans la chaîne ?

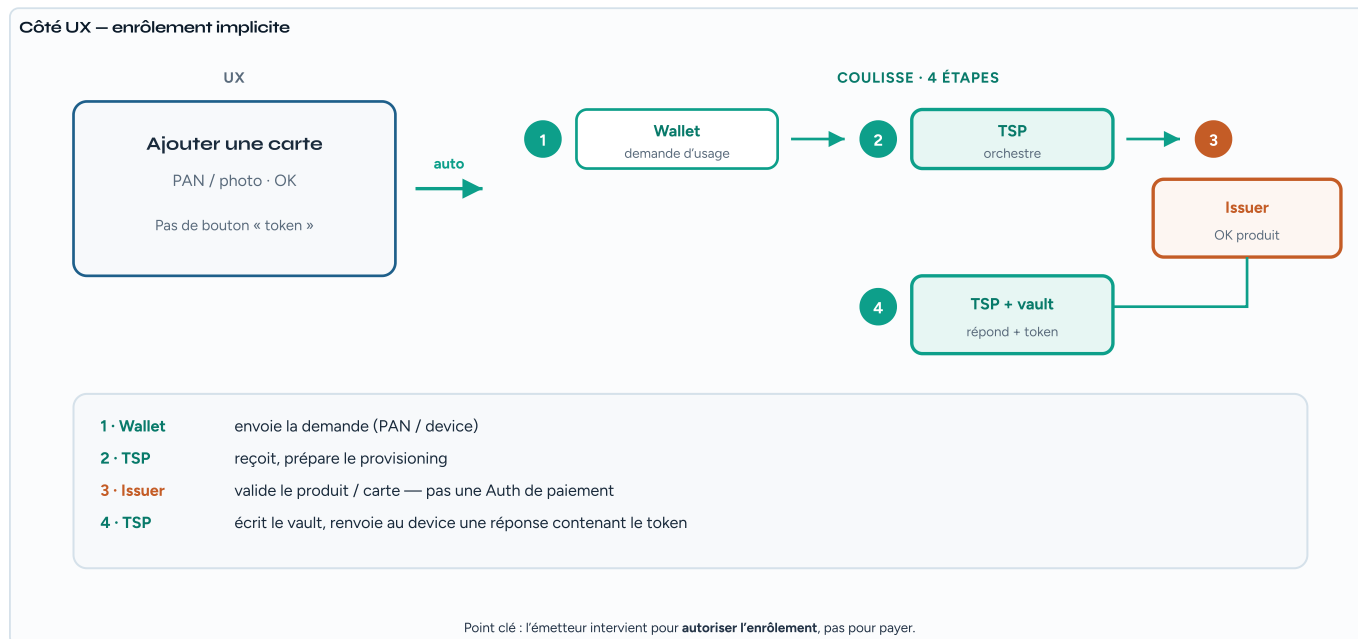
- Vault / TSP : côté **réseau / scheme** (souvent) — pas dans la caisse ni l'app marchande
- L'émetteur garde le PAN et la décision AuthZ — le TSP ne le remplace pas

Chaîne SI détaillée : [Architecture SI](#) · Qui voit token / PAN en Auth : [Lifecycle](#) · [Auth](#)

ÉMISSION

Comment naît le token (côté UX)

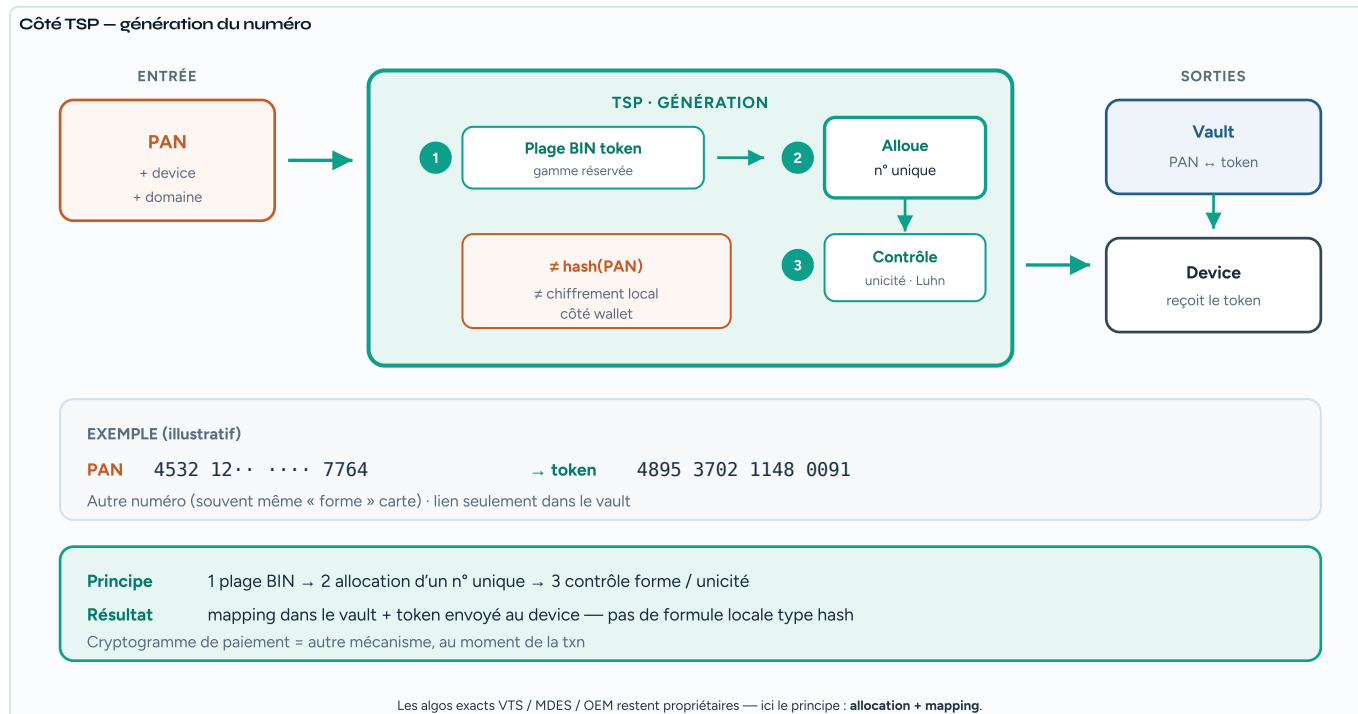
Geste simple à l'écran — en coulisse, une chaîne jusqu'à l'émetteur (contrôle produit), puis émission du token.



ÉMISSION

Côté TSP — génération du numéro

Allocation contrôlée dans une plage BIN token — ce n'est **pas** un hash(PAN) côté wallet.



CLARIFICATION

À ne pas confondre

En PCI-DSS, **troncature** et **masquage** ne sont pas synonymes — et aucun des deux n'est un token.

Troncature · Masquage · Token

Troncature

truncation · stockage

453212 ···· 7764

Digits milieu **retirés**

en base / fichier — définitif
pas de « dé-troncature » locale

PCI · rendre illisible au repos

≠ token

Masquage

masking · affichage

4532 ···· ···· 7764

Digits **cachés à l'écran**

ticket, UI, rapport imprimé
le PAN complet peut encore être stocké

PCI · limiter ce qu'on affiche

≠ token

Token

substitut · TSP

4895 3702 1148 0091

Autre numéro gouverné

domaine · device · canal
lien PAN dans le vault

≠ masquer / tronquer le PAN

≠ masking · ≠ truncation

Masquage = affichage ; troncature = stockage (digits retirés). Formats « 6+4 » courants — détail selon longueur PAN / scheme.

PCI DSS — Payment Card Industry Data Security Standard · PCI Security Standards Council.

≠ **Chiffrement simple** Un token n'est pas un PAN chiffré affiché autrement : il a un domaine et une gouvernance.

≠ **Nouveau rail** Auth → Clearing → Settlement reste intact. On change l'identifiant exposé, pas la logique monétique.

≠ **Risque zéro** Exposition réduite — fraude, device et conformité restent des sujets SI.

Suite : [Pourquoi tokeniser](#) · [Domaines d'usage](#) · [Lifecycle](#) · [Provisioning](#).

Objectifs de la tokenisation

RÔLE

Pourquoi tokeniser

On ne change pas le rail **Auth** → **Clearing** → **Settlement** : on change *ce qui est présenté* — pour réduire l'exposition, la fraude réutilisable et le scope PCI.

TROIS RAISONS

Ce que la tokenisation vise

1 · Moins d'exposition du PAN

- Le canal voit un substitut, pas le numéro de carte
- Le PAN reste chez l'émetteur / vault / TSP
- Moins de copies dans POS, apps, logs, bases marchandes

2 · Fraude plus difficile à réutiliser

- Token souvent lié à un domaine (device, canal, marchand)
- Suspendre un token ≠ bloquer toute la carte
- Ex. : téléphone perdu → revoke ciblé

3 · Conformité (PCI-DSS)

- Moins de PAN côté marchand → scope PCI réduit — détail réglementaire : [Sécurité & conformité](#)

CONTEXTE

Pourquoi surtout en digital ?

Le rail carte classique expose peu de copies persistantes ; les canaux digitaux multiplient stockage et acteurs.

Rail classique vs canaux digitaux

Rail classique

Carte plastique → POS → Auth

- PAN lit / chip / bande — geste court
- Peu de stockage durable chez le marchand
- Exposition limitée dans le temps

Token utile, pas toujours central

Canaux digitaux

Wallet · e-com · in-app · card-on-file

- PAN entrerait dans apps, serveurs, cloud
- Stockage récurrent · multi-acteurs
- Surface d'attaque & scope PCI plus larges

Token = modèle par défaut

SYNTHÈSE

Réduit · conserve · déplace

EFFET	
Réduit	Copies du PAN dans POS, apps, logs, bases marchandes
Conserve	Rail Auth → Clearing → Settlement (J1) · décision chez l'issuier
Déplace	Gouvernance du mapping vers vault / TSP · responsabilité concentrée

Scope PCI réduit côté marchand ≠ disparition des contrôles (détail : 3.4).

Domaines d'usage

MODES / DOMAINES

Où on tokenise

Un **domaine d'usage** est le **périmètre autorisé** d'un token : dans quel canal, sur quel device, parfois chez quel marchand il peut servir. Ex. : token Watch (NFC) ≠ token carte enregistrée chez un marchand (COF) — ce sont deux wallets, deux domaines. Le rail **Auth** → **Clearing** → **Settlement** reste le même ; ce qui change, c'est *qui tokenise, où vit le token et ce qui circule* à la place du PAN.

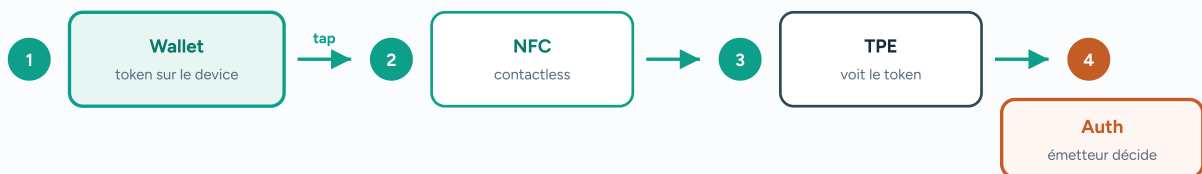
IN-STORE

Tap au POS

Le payeur ne tape pas son PAN : le device présente un token lié à l'appareil.

Wallet → Tap → TPE → Auth

FLUX IN-STORE · 4 ÉTAPES



- | | |
|-------------------|--|
| 1 · Wallet | token déjà sur le téléphone / Watch (après enrôlement) |
| 2 · NFC | le device présente token + cryptogramme — pas le PAN |
| 3 · TPE | le terminal / commerçant voit un numéro tokenisé, jamais le PAN d'origine |
| 4 · Auth | l'émetteur autorise le paiement (rail Auth → Clearing → Settlement) |
| Point clé | perte du phone → suspendre CE token ; la carte plastique reste utilisable ailleurs |

Domaine = **device** + **proximité**. Ce token ne sert pas en card-on-file web. Suite technique : Lifecycle · Provisioning.

IN-APP

Checkout natif

L'achat se fait dans l'application du marchand — token wallet ou vault PSP, pas une WebView.

App → Wallet / PSP → Backend → Auth

FLUX IN-APP · 4 ÉTAPES



- 1 · App** l'utilisateur paie dans l'app marchande (natif, pas une WebView)
- 2A · Wallet** Apple Pay / Google Pay dans l'app — le token reste côté wallet téléphone
- 2B · PSP** carte enregistrée via la passerelle — l'app n'a qu'un identifiant opaque
- 3 · Backend** reçoit une credential / token — jamais le PAN en clair (logs & base sans PAN)
- 4 · Auth** l'émetteur autorise — même rail Auth → Clearing → Settlement
- Point clé** in-app ≠ page web dans l'app · biométrie / SCA selon les règles

Deux voies possibles au même endroit « 2 » : wallet constructeur **ou** token PSP. Ex. : Uber, Deliveroo, billetterie.

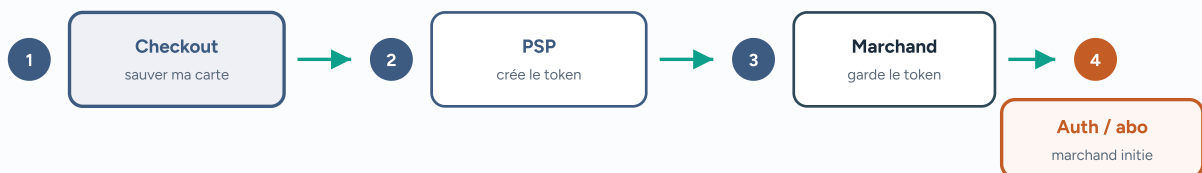
E-COMMERCE

Card-on-file

Le marchand réutilise la carte (1-clic, abonnement) en stockant un token — pas le PAN.

Checkout → PSP → Token stocké → Paiements suivants

FLUX CARD-ON-FILE · 4 ÉTAPES



- 1 · Checkout** PAN saisi une fois chez le PSP (pas en base marchande) · souvent 3DS
- 2 · PSP** tokenise · le lien PAN → token vit dans le coffre (vault / TSP)
- 3 · Marchand** stocke le token (wallet côté marchand) — jamais le PAN → scope PCI ↓
- 4 · Suite** abos / 1-clic : le marchand renvoie le token → Auth (paiement initié marchand)
- Point clé** token COF ≠ token Watch NFC — domaines non interchangeables
- Exemples** streaming · SaaS · marketplace 1-clic

Card-on-file = wallet **côté marchand** / PSP. Suite : Architecture SI · Sécurité & PCI.

SYNTHÈSE

Canal ≠ lieu de stockage

Le **canal** (magasin, app, web) dit *comment* on paie. Le **token** dit *où* il vit. Même Apple Pay sur le même iPhone : souvent

un seul token pour le tap et l'app — la carte enregistrée chez un marchand, c'en est une autre.

	TOKEN DEVICE wallet OEM (ex. Apple Pay)	TOKEN COF wallet marchand / PSP
Où il vit	Puce sécurisée du device (ex. Secure Element Apple Pay)	Coffre PSP (le marchand garde surtout un id / référence)
Canaux d'usage	Tap NFC · in-app · web wallet — ex. Apple Pay : même token device (DPAN) sur un même iPhone	Checkout web · abo · 1-clic (souvent initié par le marchand)
Qui tokenise	TSP réseau (VTS · MDES) + wallet constructeur · OK issuer à l'enrôlement	PSP / TSP card-on-file (parfois token réseau)
Mapping PAN ↔ token	Vault TSP / scheme (pas chez Apple, pas au TPE)	Vault PSP / TSP (PAN hors base marchande)
Attention	Autre device = autre token (iPhone ≠ Watch)	≠ token device Apple Pay / Google Pay
Risque type	Device perdu · fraude de proximité	Fuite des références COF · abus MIT

Si l'app enregistre la carte via le **PSP** (sans Apple / Google Pay) → token COF, pas token device. Cas avancé Apple : abo récurrents peuvent utiliser un **MPAN** (token marchand) ≠ DPAN device.

Légende — sigles

- **Wallet** — portefeuille électronique (téléphone, Watch, ou côté marchand)
- **TSP** — Token Service Provider (émet / gouverne le token)
- **PSP** — Payment Service Provider (passerelle paiement du marchand)
- **OEM** — constructeur du téléphone / OS (Apple, Google...)
- **COF** — card-on-file · carte enregistrée chez le marchand
- **VTS / MDES** — TSP Visa / Mastercard
- **TPE / POS** — terminal de paiement · **NFC** — contactless

Tokenisation réseau & cycle de vie

DÉFINITION MONÉTIQUE

Qu'est-ce que le lifecycle du token ?

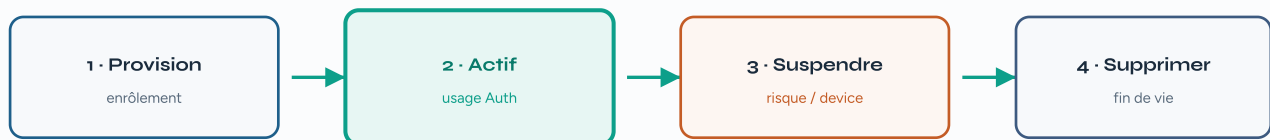
Ensemble des états et transitions d'un token : **provisioning** → **actif** (usage Auth) → **suspendre / reprendre** → **supprimer**. Distinct du cycle de la carte source : on gouverne un device / canal sans résilier le PAN. Durée = *états*, pas un TTL type OTP.

PARCOURS

Une seule carte du cycle

Quatre temps — détaillés ensuite : provisioning, stockage, Auth, gouvernance.

Provision · Actif · Suspendre · Supprimer



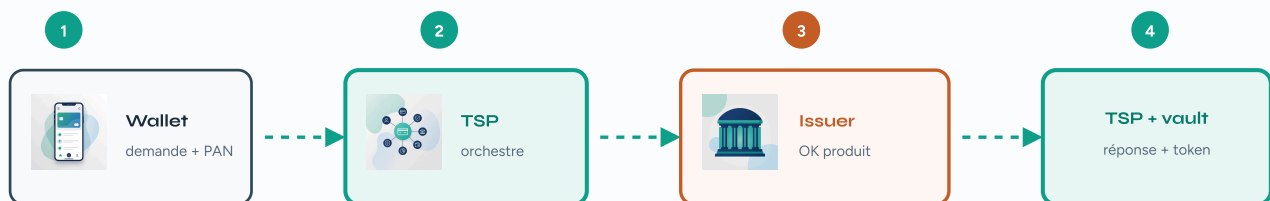
Longue durée tant qu'actif · crypto de chaque txn = éphémère · détail des actions = section Gouvernance plus bas.

PROVISIONING

Enrôlement & provisioning

Quatre temps : demande → TSP → OK émetteur (produit) → émission token + vault. ≠ Auth de paiement.

Enrôlement



- 1 Wallet envoie la demande d'usage
- 2 TSP orchestre le provisioning
- 3 Issuer valide le produit — ≠ Auth de paiement

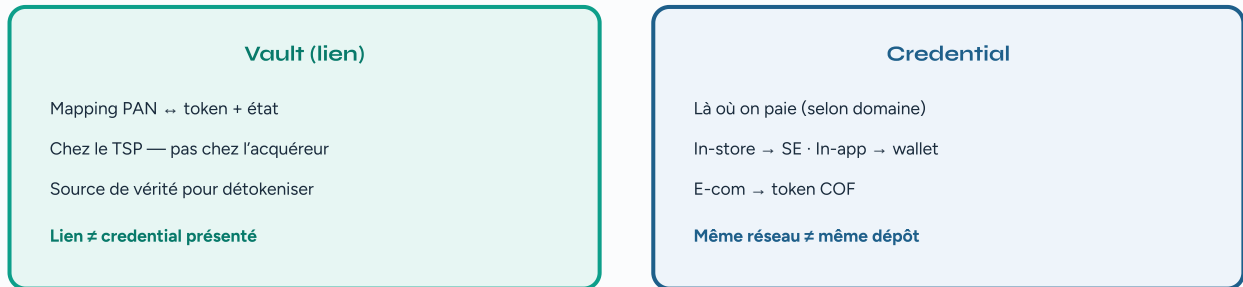
- 4 TSP écrit le vault, renvoie le token au device
Token prêt à activer / utiliser

APRÈS PROVISIONING

Où est stocké le token

Deux niveaux : **vault** (lien) vs **credential** (là où on paie). Vocabulaire vault / TSP : Définition ; terrains : Domaines.

Stockage dual



USAGE · AUTH

Qui voit le token · qui voit le PAN

En **network tokenization**, c'est le **token** qui part en autorisation jusqu'à l'acquéreur — le PAN n'apparaît qu'au moment de la détokerisation (réseau / TSP), pour joindre l'issuer.

Chaîne Auth tokenisée



Détail des étapes

- 1 • **Présentation** — Le device (ou le checkout) envoie le token + un cryptogramme dynamique. Ce n'est pas le PAN d'origine qui sort du wallet / de l'app. Même logique POS NFC, in-app SDK ou gateway e-com tokenisé. Identifiant présenté = token · preuve d'usage = crypto.
- 2 • **Jusqu'à l'acquéreur = TOKEN** — Acceptation (POS / PSP) puis acquéreur reçoivent et routent le token — souvent un DPAN. L'acquéreur traite une Auth « comme une carte », mais sans le PAN d'origine. C'est l'intérêt PCI de la network tokenization le long de la chaîne d'acceptation. Chez l'acquéreur, c'est le token qui part en Auth — pas le PAN.
- 3 • **Réseau / TSP = détokerisation** — Le schéma / TSP lit le vault : token → PAN (mapping) + contrôles domaine / crypto. Puis route vers l'émetteur de la carte source. Clearing / settlement : même rail J1 — l'identifiant présenté en amont a changé. Détokeriser ≠ « renvoyer le PAN à l'acquéreur » : c'est pour joindre l'issuer.
- 4 • **Issuer = décision sur le compte** — L'émetteur autorise sur le produit / compte lié au PAN d'origine. Il peut aussi appliquer des règles liées au token (device, domaine, état actif). OK / KO remonte la chaîne — le commerçant voit le résultat, pas le PAN. Rail Auth → Clearing → Settlement inchangé dans sa logique (J1).

Deux modèles de token

Deux modèles de token

Network tokenization

VTS · MDES · wallets OEM...

Token va jusqu'à l'acquéreur

Détokenisation au réseau / TSP

Acquéreur : TOKEN · pas PAN

Le token va plus loin dans la chaîne

Vault marchand / PSP seul

Token opaque côté commerçant

Le PSP peut détokeriser avant

et envoyer le PAN à l'acquéreur

Acquéreur : peut revoir du PAN

Protection surtout côté commerçant

Même mot « token » — portée différente jusqu'à l'acquéreur

Routing détaillé (qui acquiert · qui AuthZ) : 3.3 · Architecture SI.

GOUVERNANCE

Activer · Suspendre · Supprimer

Détail des états de la carte du cycle — actions fines sur un contexte, sans forcément toucher toute la carte.

Actions TSP

Activer

token utilisable

Suspendre

gel temporaire

Supprimer

fin de vie

Détail des étapes

- **Activer / reprendre** — Après provisioning (ou après un suspend), le token peut servir en Auth. État « actif » = longue durée jusqu'à événement (risque, perte, fin d'usage). ≠ cryptogramme : le token reste ; chaque txn génère un crypto neuf. Carte source intacte — on active un contexte, pas « toute la carte ».
- **Suspendre** — Gel d'un device / canal — ex. téléphone perdu, suspicion fraude. La carte plastique et les autres tokens restent utilisables. Reversible (resume) si le risque disparaît. Gouvernance fine : pas besoin de résilier le PAN.
- **Supprimer** — Fin de vie du token (désenrôlement, fin d'app, device changé...). Nouveau device → en général nouveau provisioning (nouveau contexte). COF : renouvellement carte peut garder le même token si le TSP maj le mapping. Cycle token ≠ cycle carte — c'est le point clé.

Architecture SI tokenisation

DÉFINITION

Que montre l'architecture SI ?

Les briques qui **émettent**, **stockent** et **présentent** le token — puis qui **acquiert** le flux Auth et **route** jusqu'à l'AuthZ émetteur. Cycle de vie (états) : 3.2.

ÉLÉMENTS SI

Où tournent les briques

Briques tokenisation



Tokenisation réseau (VTS · MDES...)

Service scheme / TSP — le token va jusqu'à l'acquéreur · ≠ vault marchand seul

TSP = gouvernance token · Issuer = racine carte + décision AuthZ

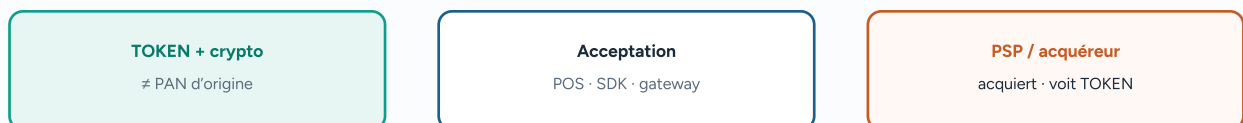
ROUTAGE AUTH

Qui acquiert · comment ça route

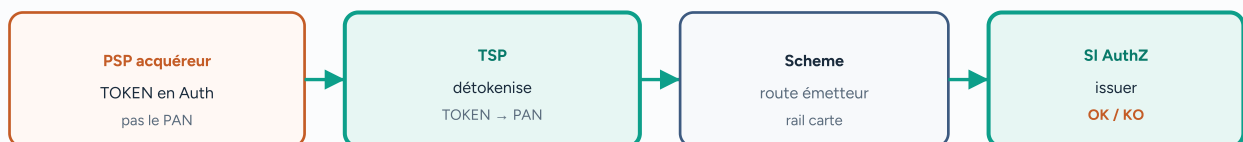
Network tokenization : jusqu'à l'acquéreur inclus = **TOKEN** (+ crypto). Détokenisation au TSP / scheme → **AuthZ SI issuer**.

Flux Auth tokenisé

A · PRÉSENTATION — ce qui sort du device / checkout



B · ROUTAGE — détoken puis AuthZ



Jusqu'à l'acquéreur inclus → TOKEN · Après TSP → compte / PAN pour décider

Clearing / settlement = suite J1 · états du token = 3.2

Vault marchand / PSP seul : le PSP peut détokeniser *avant* l'acquéreur — celui-ci peut alors revoir du PAN. Détail domaines : 3.1.

SYNTHÈSE

Qui voit quoi · qui AuthZ

ACTEUR	VOIT	RÔLE
App / wallet	TOKEN (+ crypto)	Présente le credential
Acceptation · PSP / acquéreur	TOKEN (network tok.)	Acquiert le flux Auth
TSP	Mapping TOKEN ↔ PAN	Gouverne · détokenise
Scheme	Rail / routage	Route vers l'émetteur
SI issuer	Compte / PAN + règles token	AuthZ OK / KO

TSP ≠ issuer : gouvernance du token d'un côté ; produit carte et décision AuthZ de l'autre. Network tokenization (VTS / MDES...) = service scheme / TSP.

Sécurité & conformité

DÉFINITION MONÉTIQUE

Que couvre ce bloc ?

La tokenisation protège l'**identifiant** (moins de PAN exposé). Elle s'accompagne d'autres briques : lier le token à un **device**, authentifier le **porteur** (SCA / DSP2), prouver **chaque paiement** (cryptogramme), et gérer **PCI / données**.
Tokeniser ≠ authentifier ≠ être « conforme » d'un coup.

Identifiant sécurisé ≠ porteur authentifié ≠ scope PCI fermé.

VOCABULAIRE

Socle sécurité réutilisable

Trois leviers distincts — chacun répond à une question différente.

Device binding · SCA · Cryptogrammes

Device binding

Où peut vivre / servir le token ?

Token ↔ cet appareil

Ex. : token iPhone ≠ Watch
perte phone → suspendre CE token

Protège le contexte d'usage

pas l'identité du porteur

SCA / DSP2

Qui paie — est-ce le bon porteur ?

Auth forte du porteur

Ex. : biométrie, 3DS, OTP
2 facteurs parmi savoir / avoir / être

Protège l'identité / le consentement

≠ avoir un token

Cryptogrammes

Cette txn — est-elle rejouable ?

Preuve dynamique par paiement

Valeur neuve à chaque Auth
liée au token / device / montant...

Protège contre le replay

≠ le token (durable)

Token remplace le PAN (identifiant)

Les 3 binding = où · SCA = qui · crypto = cette txn — tokeniser ≠ « être SCA »

CONFORMITÉ

PCI-DSS & protection des données

La tokenisation aide à réduire le scope — elle ne ferme pas le dossier conformité.



	AVANT TOKENISATION	APRÈS TOKENISATION
Chez le marchand	PAN stocké / transmis → scope PCI large	TOKEN (souvent) → scope potentiellement réduit
Ce qui reste	Vault / TSP, audit, gouvernance, SCA, responsabilités issuer	
Piège	« Tokenisé => conforme » — faux ; réduction à valider, pas à proclamer	

PCI-DSS

- Réduction d'exposition du PAN
- Allègement possible de périmètres
- Gouvernance ne disparaît pas

Protection des données

- SCA reste un sujet distinct
- Traçabilité et conservation
- Responsabilités TSP / issuer / wallet

RÔLE

Ce qu'on réduit, ce qu'on garde

Réduit Exposition du PAN, réutilisation triviale, certains risques côté marchand.

Conservé Fraude, gouvernance des tokens, compromission de device, erreurs d'intégration, exigences d'audit.

Déplacé Une part de responsabilité se concentre sur TSP, issuer, wallet et briques de confiance.